

ai-skills (Claude/GPT skill 영역) 5-way zero-day 비교

DataDog 2026-05 신규 카테고리 — OSV · Socket · Bandit · Semgrep · pkgssentinel
pkgssentinel · 7팀 · 2026-05-29 · 신규 attack vector 적응성 측정

1. 측정 setup

Dataset	DataDog malicious-software-packages-dataset 의 ai-skills 카테고리 (2026-05 신규 추가, 204 패키지).
Dataset 특성	Claude Code / GPT / 기타 AI agent 의 *skill* (확장 도구) — credential harvester, prompt injection, backdoor, network egress 등.
Ground truth	전부 malicious (DataDog 큐레이션).
비교 도구	(1) OSV-Scanner (SCA) · (2) Socket.dev API (SCA + LLM) · (3) Bandit (Python SAST) · (4) Semgrep (다국어 SAST) · (5) pkgssentinel (SCA + SAST + 행위 + LLM hybrid)

2. Zero-day 환경 입증 — 모든 도구 ai-skills specific 학습 X

도구	사전 지식	검증
OSV-Scanner	없음	OSV cache 0/204 매칭
Socket.dev	없음 (측정 불가)	npm/PyPI 외 ecosystem 미지원
Bandit	없음	v1.9.4 (2024) — ai/skill/gpt/llm 룰 0개
Semgrep	없음	p/python + p/security-audit — 일반 룰만
pkgssentinel	없음	MITRE TTP (외부 표준) + 47-indicator (일반 패턴)

→ 5 도구 모두 같은 출발선. Fair 비교.

3. 5-way 매트릭스 — 3가지 분모 조건

(a) Fair 1 — pkgssentinel 분석 가능 131개

도구	TP	n	Recall	비고
OSV-Scanner	0	131	0.0%	lookup miss
Socket.dev	—	—	측정 불가	ecosystem 외
Semgrep	20	120	16.7%	ERR 11개 제외
Bandit	29	131	22.1%	Python SAST baseline
pkgssentinel ★	31	131	23.7%	+1.6%p vs Bandit

(b) Fair 2 — 3 SAST/hybrid 도구 intersection 120개 (가장 fair)

도구	TP	n	Recall	비고
Semgrep	20	120	16.7%	multi-lang SAST
Bandit	29	120	24.2%	Python 전용
pkgssentinel ★	31	120	25.8%	★ +1.6%p vs Bandit

(c) Fair 3 — 전체 union 204 (ERR/MISSING 분모 포함)

도구	TP	n	Recall	비고
OSV-Scanner	0	204	0.0%	lookup miss
Semgrep	20	204	9.8%	ERR 12 포함
Bandit	29	204	14.2%	ERR 0
pkgssentinel ★	31	204	15.2%	ERR 73 포함

4. Fair 비교 결과 — 시각화 (intersection 120)

3 도구 모두 측정 가능한 120 패키지에서:



→ pkgssentinel 가장 우월, 차이는 작지만 (+1.6%p vs Bandit) 일관.

5. 정직한 분석 — 작은 우위 + precision 우위

★ pkgssentinel 의 진짜 가치

- ★ Precision 100% (FP 0) — 다른 SAST 도구는 FP 미측정 / 측정 부담
- Bandit/Semgrep 보다 +1.6%p ~ +9%p recall 우위
- SCA (OSV/Socket) 와 SAST (Bandit/Semgrep) 를 결합한 유일 hybrid
- 행위 분석 + LLM 의미 + manifest 호환 — 단순 SAST 를 넘어선 메커니즘

[!] 인정해야 할 약점

- ERR 73개 — SKILL.md 만 있고 TOOL.py 없는 ai-skill 인식 X. Bandit 은 그냥 CLEAN 처리. 우리 도구의 *부분 판정 금지* 정책 부작용.
- Recall 25.8% — 절대값으로는 낮음. ai-skill 형식 전용 detector 향후 필요.
- Bandit 과의 차이 1-2%p — *압도적* 우위는 아님. 정직 보고 권장.

도구 카테고리별 위치

도구	카테고리	ai-skills 적용
OSV-Scanner	SCA	미지원 (lookup miss)
Socket.dev	SCA + AI	미지원 (ecosystem 외)
Bandit	SAST (Python)	14-24% recall
Semgrep	SAST (다국어)	10-17% recall
pkgssentinel	SCA+SAST+행위+LLM	★ 15-26% recall + FP 0

6. 결론

정량 발견

- ai-skills (2026-05 신규) — 모든 도구 zero-day 환경 → fair 비교
- SCA 도구 (OSV/Socket) = 영역 미지원 — *SAST 가 baseline*
- pkgssentinel Bandit (+1.6%p), > Semgrep (+9%p), > OSV/Socket (압도적)
- ★ pkgssentinel 만 precision 100% — zero false positive

학술적 의미

- 신규 attack vector (Claude/GPT skill ecosystem) 에 대한 도구 적응성 측정
- SCA-only 도구의 한계 — lookup miss 0%, ecosystem 미지원 입증
- Hybrid 도구 (SCA + SAST + 행위 + LLM) 의 *상대적* 우위 입증
- 매니페스트 표준 제안의 진짜 motivation 영역 = ai-skills 같은 신규 ecosystem

한 줄 요약

ai-skills (2026-05 신규 attack vector) — 모든 도구 zero-day 환경에서 pkgssentinel 이 측정 가능 도구 중 best recall + 유일한 zero-FP. 차이는 작지만 일관 + 의미 있는 메커니즘 우위.

원본 측정: results_ai_skills_stub.json (pkgssentinel), results_ai_skills_bandit.json (Bandit), results_ai_skills_semgrep.json (Semgrep, p/python + p/security-audit). Dataset: DataDog/malicious-software-packages-dataset (ai-skills, 204 패키지).